

Unit-1

Syllabus: Basic Principles, Security Goals, Cryptographic Attacks, Services and Mechanisms, Mathematics of Cryptography

1.1. Basic Principles

Introduction to Information Security:

We are living in the information age. We are generating information at every stage of our lives daily and we need to protect that information. In other words, information is an asset that has a value like any other asset. As an asset information needs to be secured from attacks.

To protect information, information needs to be hidden from unauthorized access (confidentiality), protected from unauthorized change (integrity), and available to an authorized entity when it is needed (availability).

Until a few decades ago, the information collected by an organization was stored on physical files. The confidentiality of the file was achieved by restricting the access to a few authorized and trusted people in the organization. In the same way, only a few authorized people were allowed to change the contents of the files. Availability was achieved by designating atleast one person who would always have access to the files.

With the advent of computers, information storage became electronic. Instead of being stored on physical media, it was stored in computers. The three security requirements, however, did not change. The files stored in computers require confidentiality, integrity and availability. The implementation of these requirements, however, is different and more challenging.

1.2. Security Goals

There are three primary goals in any security service. These are confidentiality, integrity and availability.

Confidentiality: The principle of confidentiality is that only the sender and the intended recipient should be able to access the contents of a message. Confidentiality gets compromised if an unauthorized person is able to access the message. Example of this could be a confidential email message sent by user A to user B, which is accessed by user C without the permission or knowledge of A and B. This type of attack is called interception.

Integrity: When the contents of a message are changed after the sender sends it, but before it reaches the intended recipient, we say that the integrity of the message is lost. For example, consider that user A sends message to user B. User C tampers with a message originally sent by user A, which is actually destined for user B. User C somehow manages to access it, change its contents and send the changed message to user B. User B has no way of knowing that the contents of the message changed after user A had sent it. User A also does not know about this change. This type of attack is called modification.

Availability: The principle of availability is that resources should be available to authorized parties at all times. For example, due to the intentional actions of an unauthorized user C, an authorized user A may not be able to contact a server B. This would defeat the principle of availability. Such an attack is called interruption.

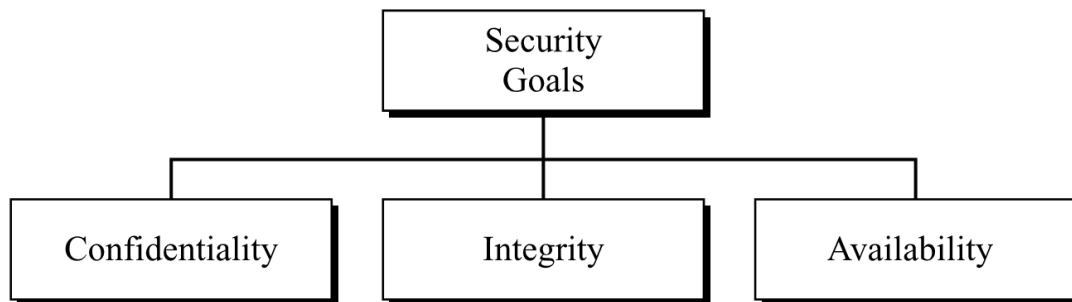


Fig-1.1: Taxonomy of Security Goals

1.3. Security Attacks

Security Attack: Any action that compromises the security of information owned by an organization.

Vulnerability: A vulnerability is an identified weakness in a controlled system, where controls are not present or are no longer effective.

Threat: A potential for violation of security, which exists when there is a circumstance, capability, action, or event that could breach security and cause harm. That is, a threat is a possible danger that might exploit a vulnerability.

Attack: An attack is a deliberate act that takes advantage of a vulnerability to compromise a controlled system. It is accomplished by a threat agent that damages or steals an organization's information or physical asset.

Attacks are classified as **passive** and **active**. A passive attack is an attempt to learn or make use of information from the system without affecting system resources, whereas an active attack is an attempt to alter system resources or affect their operation.

Passive Attacks

Passive attacks are in the nature of eavesdropping on or monitoring the transmissions. The goal of the opponent is to obtain information that is being transmitted.

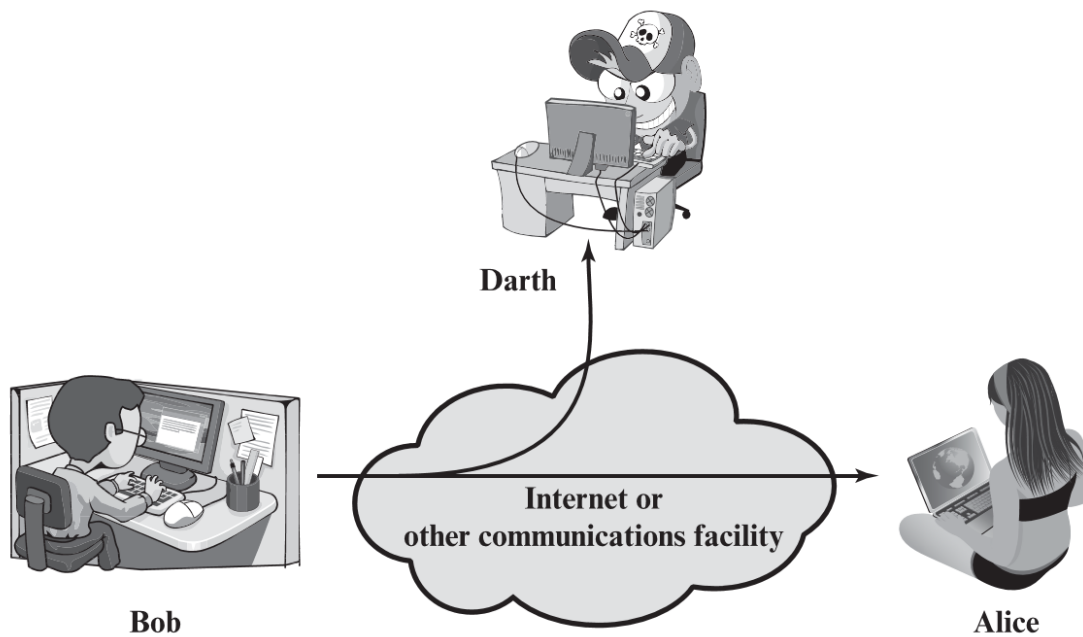
Two types of passive attacks are “release of message contents (Snooping)” and “traffic analysis”.

The release of message contents is easily understood. A telephone conversation, an electronic mail message, and a transferred file may contain sensitive or confidential information. We would like to prevent an opponent from learning the contents of these transmissions.

A second type of passive attack, traffic analysis, is subtler.

To protect information from passive attack, we must mask the contents of messages or other information traffic so that opponents, even if they captured the message, could not extract the information from the message. The common technique for masking contents is encryption. If we had encryption protection in place, an opponent might still be able to observe the pattern of these messages. The opponent could determine the location and identity of communicating hosts and could observe the frequency and length of messages being exchanged. This information might be useful in guessing the nature of the communication that was taking place.

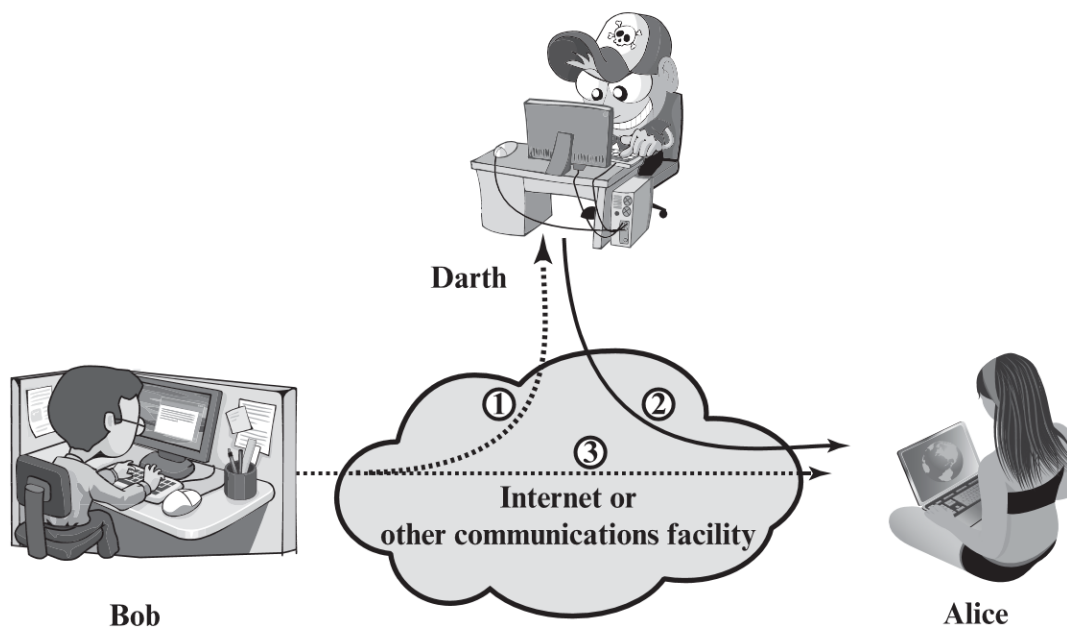
Passive attacks are very difficult to detect because they do not involve any alteration of the data.



(a) Passive attacks

Active Attacks

Active attacks involve some modification of the data stream or the creation of a false stream and can be subdivided into five categories: masquerade, replay, modification of messages, Repudiation and denial of service.



(b) Active attacks

Taxonomy of Attacks

Three goals of security, confidentiality, integrity, and availability can be threatened by security attacks. Attacks are divided into three groups related to the security goals.

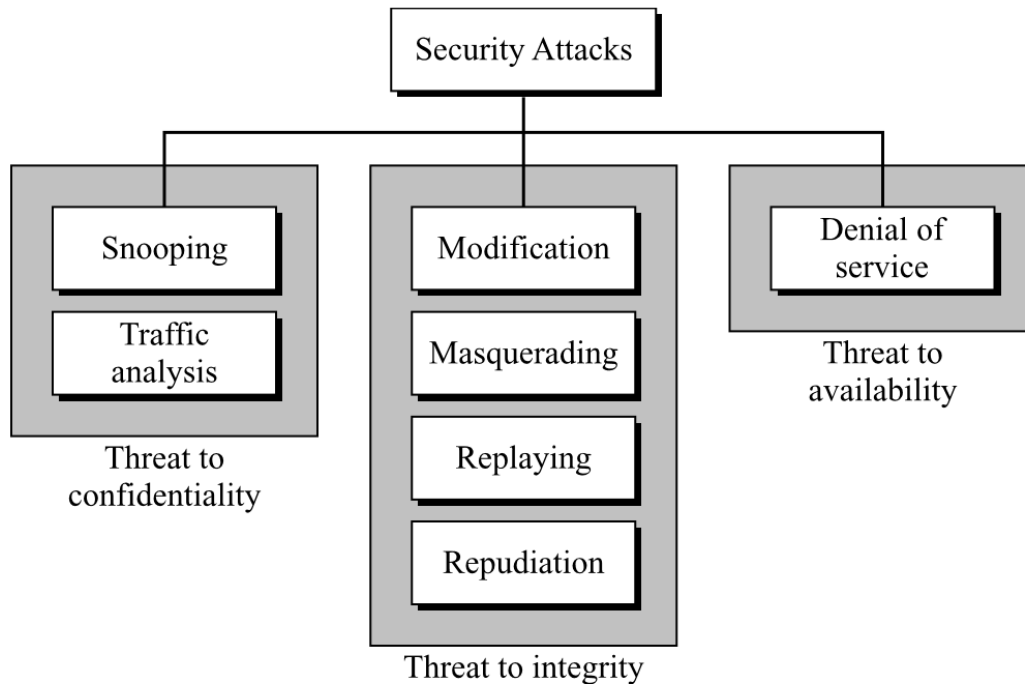


Fig-1.2: Taxonomy of Attacks

Attacks Threatening Confidentiality

In general, two types of attacks threaten the confidentiality of information: snooping and traffic analysis.

Snooping

Snooping refers to unauthorized access to or interception of data. For example, a file transferred through the Internet may contain confidential information. An unauthorized entity may intercept the transmission and use the contents for her own benefit. To prevent snooping, the data can be made non-intelligible to the interceptor by using encipherment techniques.

Traffic Analysis

Although encipherment of data may make it non-intelligible for the interceptor, she can obtain some other type information by monitoring online traffic. For example, she can find the electronic address (such as the e-mail address) of the sender or the receiver. She can collect pairs of requests and responses to help her guess the nature of transaction.

Attacks Threatening Integrity

The integrity of data can be threatened by several kinds of attacks: modification, masquerading, replaying, and repudiation.

Modification

After intercepting or accessing information, the attacker modifies the information to make it beneficial to herself. For example, a customer sends a message to a bank to do some transaction. The attacker intercepts the message and changes the type of transaction to benefit herself. Note that sometimes the attacker simply deletes or delays the message to harm the system or to benefit from it.

Masquerading

Masquerading, or spoofing, happens when the attacker impersonates somebody else. For example, an attacker might steal the bank card and PIN of a bank customer and pretend that she is that customer. Sometimes the attacker pretends instead to be the receiver entity. For example, a user tries to contact a bank, but another site pretends that it is the bank and obtains some information from the user.

Replaying

Replaying is another attack. The attacker obtains a copy of a message sent by a user and later tries to replay it. For example, a person sends a request to her bank to ask for payment to the attacker, who has done a job for her. The attacker intercepts the message and sends it again to receive another payment from the bank.

Repudiation

This type of attack is different from others because it is performed by one of the two parties in the communication: the sender or the receiver. The sender of the message might later deny that she has sent the message; the receiver of the message might later deny that he has received the message. An example of denial by the sender would be a bank customer asking her bank to send some money to a third party but later denying that she has made such a request. An example of denial by the receiver could occur when a person buys a product from a manufacturer and pays for it electronically, but the manufacturer later denies having received the payment and asks to be paid.

Attacks Threatening Availability

Denial of Service

Denial of service (DoS) is a very common attack. It may slow down or totally interrupt the service of a system. The attacker can use several strategies to achieve this. Attacker might send so many bogus requests to a server that the server crashes because of the heavy load. The attacker might intercept and delete a server's response to a client, making the client to believe that the server is not responding. The attacker may also intercept requests from the clients, causing the clients to send requests many times and overload the system.

1.4. Services and Mechanisms

The International Telecommunication Union-Telecommunication Standardization Sector provides some security services and some mechanisms to implement those services. Security services and mechanisms are closely related because a mechanism or combination of mechanisms are used to provide a service.

Security Services

ITU-T (X.800) has defined five services related to the security goals and attacks we defined in the previous sections.

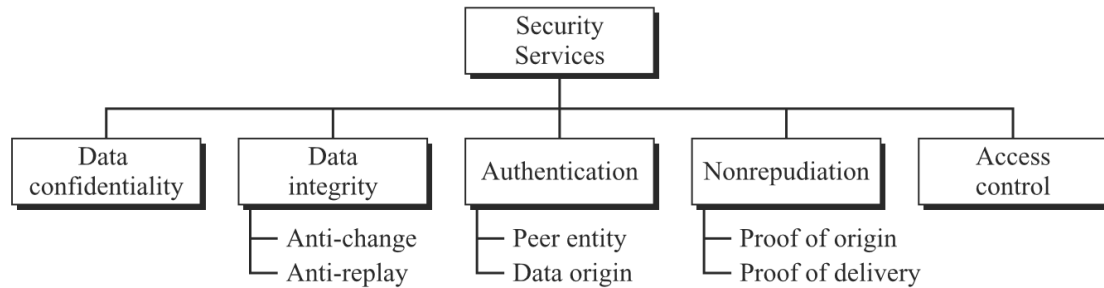


Fig 1.3: Security Services

Data Confidentiality: Data confidentiality is designed to protect data from disclosure attack. Confidentiality is the protection of transmitted data from passive attacks. The service as defined by X.800 is very broad and encompasses confidentiality of the whole message or part of a message and also protection against traffic analysis. That is, it is designed to prevent snooping and traffic analysis attack.

Data Integrity: Data integrity is designed to protect data from modification, insertion, deletion, and replaying by an adversary. It may protect the whole message or part of the message. A connection-oriented integrity service deals with a stream of messages and assures that messages are received as sent with no duplication, insertion, modification, reordering, or replays. On the other hand, a connectionless integrity service deals with individual messages without regard to any larger context, generally provides protection against message modification only.

Authentication: The authentication service is concerned with assuring that a communication is authentic. This service provides the authentication of the party at the other end of the line. In connection-oriented communication, it provides authentication of the sender or receiver during the connection establishment (peer entity authentication). In connectionless communication, it authenticates the source of the data (data origin authentication).

Nonrepudiation: Nonrepudiation service protects against repudiation by either the sender or the receiver from denying message transmission or receipt of message. In nonrepudiation with proof of the origin, the receiver of the data can later prove the identity of the sender if denied. In nonrepudiation with proof of delivery, the sender of data can later prove that data were delivered to the intended recipient.

Access control: Access control provides protection against unauthorized access to data. In the context of network security, access control is the ability to limit and control the access to host systems and applications via communications links. To achieve this, each entity trying to gain access must first be identified, or authenticated, so that access rights can be tailored to the individual.

Security Mechanism

ITU-T (X.800) also recommends some security mechanisms to provide the security services.

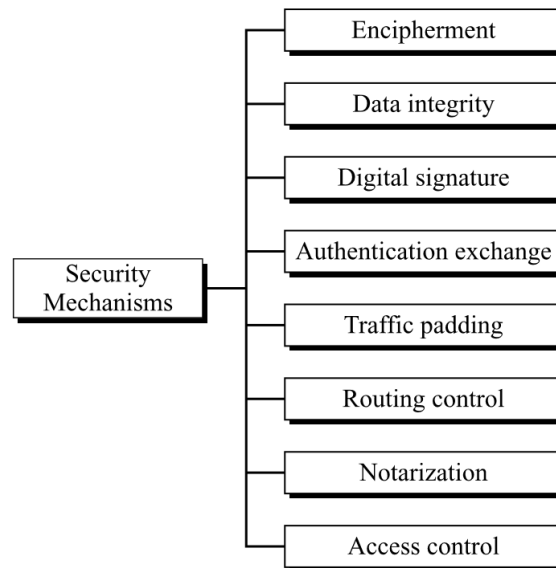


Fig 1.4: Security Mechanisms

Encipherment: This is the process of using mathematical algorithms to transform data into a form that is not readable. Encipherment, hiding or covering data, can provide confidentiality. It can also be used to complement other mechanisms to provide other services. cryptography and steganography are used to hide data.

Data Integrity: A variety of mechanisms may be used to assure the integrity of a data unit or stream of data units. The data integrity mechanism appends to the data a short checkvalue that has been created by a specific process from the data itself. The receiver receives the data and the checkvalue. He creates a new checkvalue from the received data and compares the newly created checkvalue with the one received. If the two checkvalues are the same, the integrity of data has been preserved.

Digital Signature: A digital signature is a means by which the sender can electronically sign the data and the receiver can electronically verify the signature. The sender uses a process that involves showing that she owns a private key related to the public key that she has announced publicly. The receiver uses the sender's public key to prove that the message is indeed signed by the sender who claims to have sent the message.

Authentication Exchange: This mechanism is intended to ensure the identity of an entity by means of information exchange. In authentication exchange, two entities exchange some messages to prove their identity to each other. For example, one entity can prove that she knows a secret that only she is supposed to know.

Traffic Padding: Traffic padding means inserting some bogus/dummy data into the data traffic to thwart the adversary's attempt to use the traffic analysis.

Routing Control: Routing control means selecting and continuously changing different available routes between the sender and the receiver to prevent the opponent from eavesdropping on a particular route.

Notarization: This is the use of a trusted third party to assure certain properties of a data exchange. Notarization means selecting a third trusted party to control the communication

between two entities. This can be done, for example, to prevent repudiation. The receiver can involve a trusted party to store the sender request in order to prevent the sender from later denying that she has made such a request.

Access Control: Access control uses methods to prove that a user has access right to the data or resources owned by a system. A variety of mechanisms are available that enforce access rights to resources.

Relationship between services and mechanisms

The following table shows the relationship between the security services and the security mechanisms. It shows that three mechanisms (encipherment, digital signature, and authentication exchange) can be used to provide authentication and encipherment mechanism may be involved in three services (data confidentiality, data integrity, and authentication)

Security Services	Security Mechanisms
Data confidentiality	Encipherment and routing control
Data integrity	Encipherment, digital signature, data integrity
Authentication	Encipherment, digital signature, authentication exchanges
Nonrepudiation	Digital signature, data integrity, and notarization
Access control	Access control mechanism

1.5. Mathematics of Cryptography

Security Implementation Techniques

1. Steganography
2. Cryptography

Steganography

Cryptography